# Nätverkssäkerhet

Kryptografi

# Vad krävs för att säkra kommunikation?

- **Autentisering (Authentication)**
  - Kommunicerar vi med rätt person/enhet?
- **Dataintegritet / Riktighet (Integrity)**
  - Är meddelandet trovärdigt, kan det ha blivit ändrat på vägen?
- **Konfidentialitet (Confidentiality)**
  - Har meddelandet blivit skyddad från att läsas av obehöriga parter?

- **OBS:** Notera att detta inte är att förväxla med CIA-triaden

# Autentisering (Authentication)

- Authentication = Bevisa vem du är
- ”Non-repudiation”
  - Man ska inte kunna förneka att man gjort något
  - Endast sändaren har den info som behövs (privat nyckel) för att skicka den data som inkommit
- Authentication kan göras genom HMAC, pre-shared keys, digitala certifikat, användarnamn/lösenord, etc.

# Konfidentialitet - Confidentiality

- Informationen ska endast kunna **förstås och tolkas av rätt parter**
- De egentliga paketen är synliga för någon som avlyssnar men informationen är omöjlig att tolka
- Detta utförs med hjälp av kryptering, exempelvis *AES256*
- Försök att lösa detta: **Etarvqitcrja ku hwp**

# Confidentiality - exempel

- Detta var ett Caesar-cipher med nyckeln 2
- Det som skickades var: **Cryptography is fun**

# Dataintegritet (Integrity)

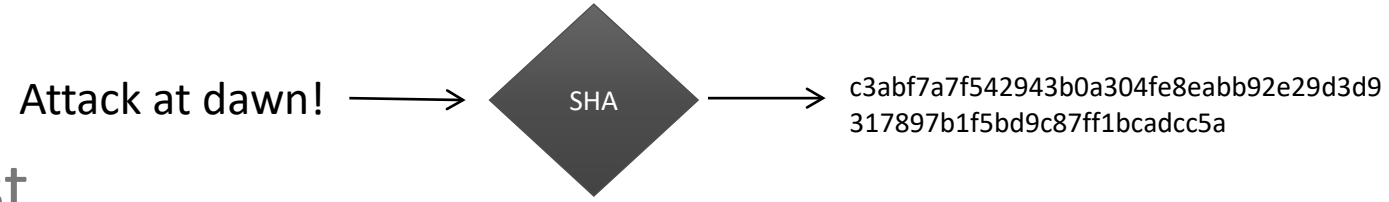
- Benämns på svenska också ibland som **tillförlitlighet**
- Säkerställer att data **inte manipulerats** under transport/lagring
- Man använder sig av en kryptografisk hashsumma för att se om innehållet har ändrats, t.ex. *SHA256*
- För att se till att inte en hacker ändrar till hash-summan efter sina ändringar använder man sig av HMAC (Hashed Message Authentication Code)

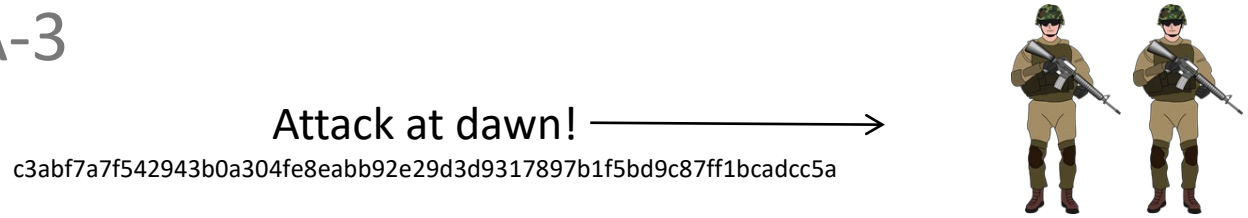
CC0F360BFC72BE8AC205BF10CD39987F00BDBF1EE33CDA96395638075C1E3452

# Kryptografiska hashsummor

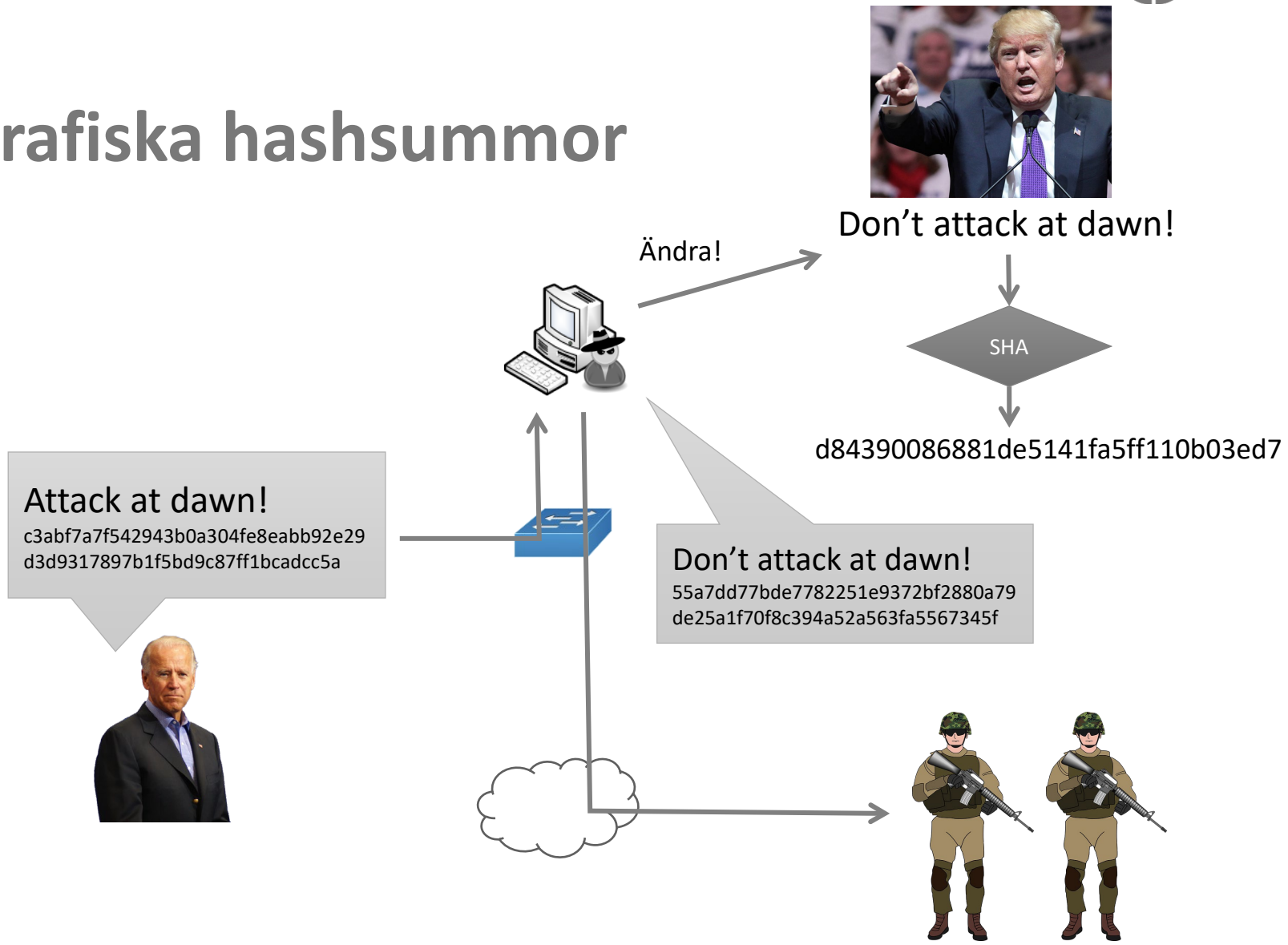
# Kryptografiska hashsummor

- En hash är en envägskryptering
- Kan ge dataintegritet och autentisering
- Samma ingångsvärde ger alltid samma hash-värde
- Värdelöst för att kryptera själva meddelandet, men kan verifiera dataintegriteten
- **SHA (Secure Hash Algorithm)** är vanligast, t.ex. SHA-2 och SHA-3



# Kryptografiska hashsummor

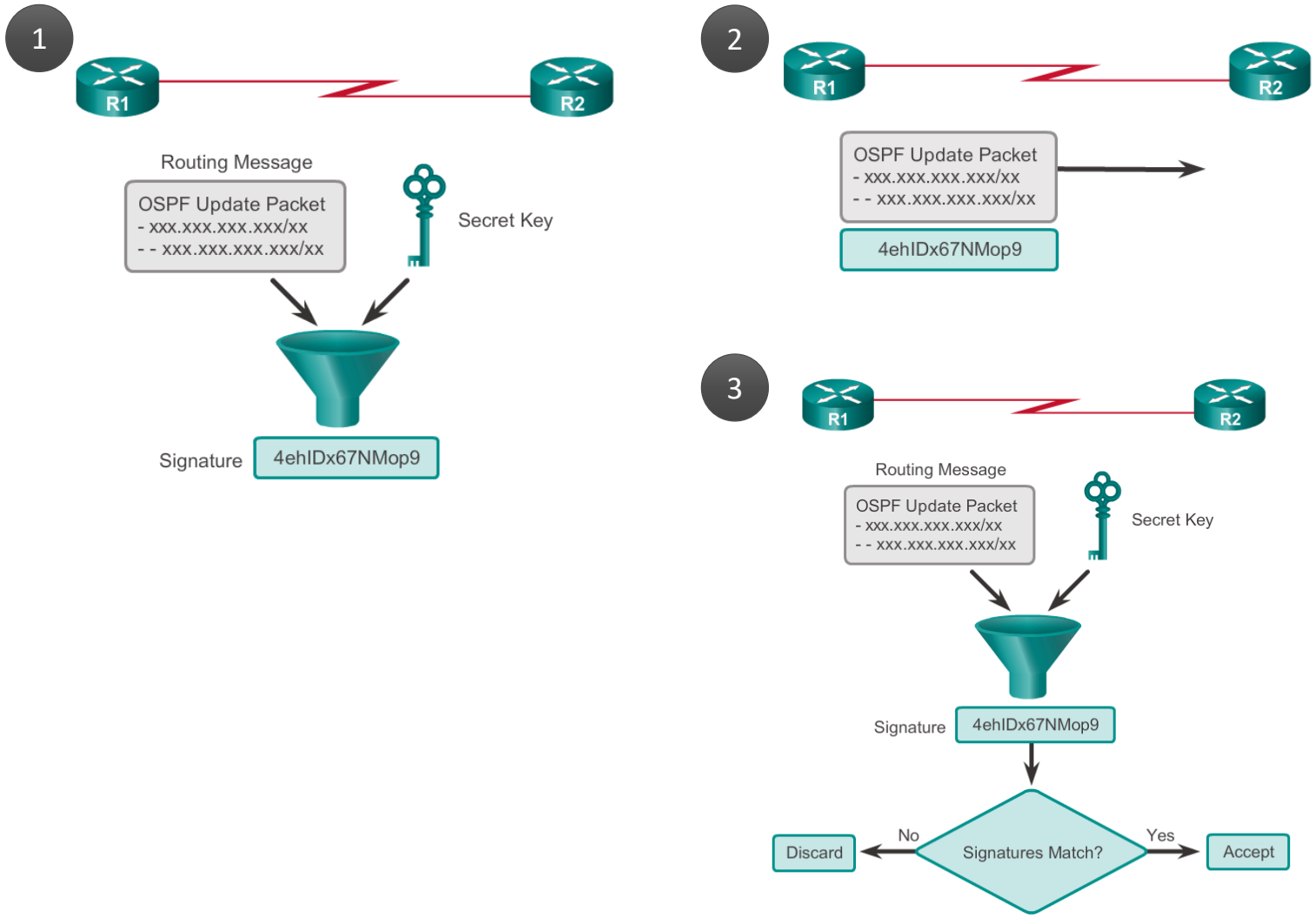


# HMAC

- **Hashed Message Authentication Code**
- Fungerar som vanlig hashsumma, men en delad nyckel (PSK) inkluderas när hashen skapas
  - Endast den som har den delade nyckeln kan skapa och verifiera äktheten på meddelandet
- HMAC-funktioner
  - HMAC-MD5
  - HMAC-SHA256

# Användningsområden HMAC

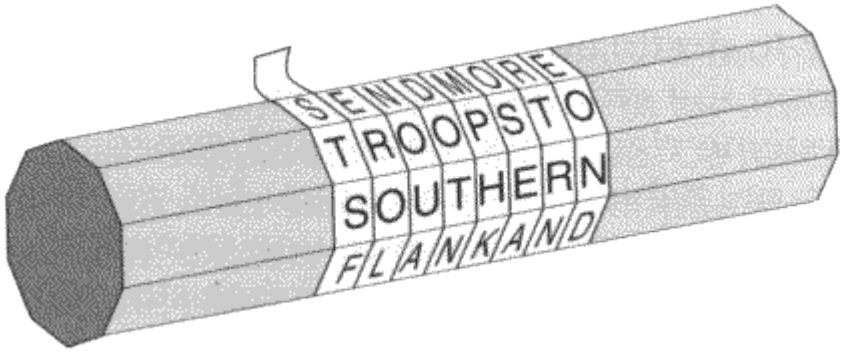
- HMAC används bland annat i:
  - IPsec
  - Routinguppdateringar



# Historia

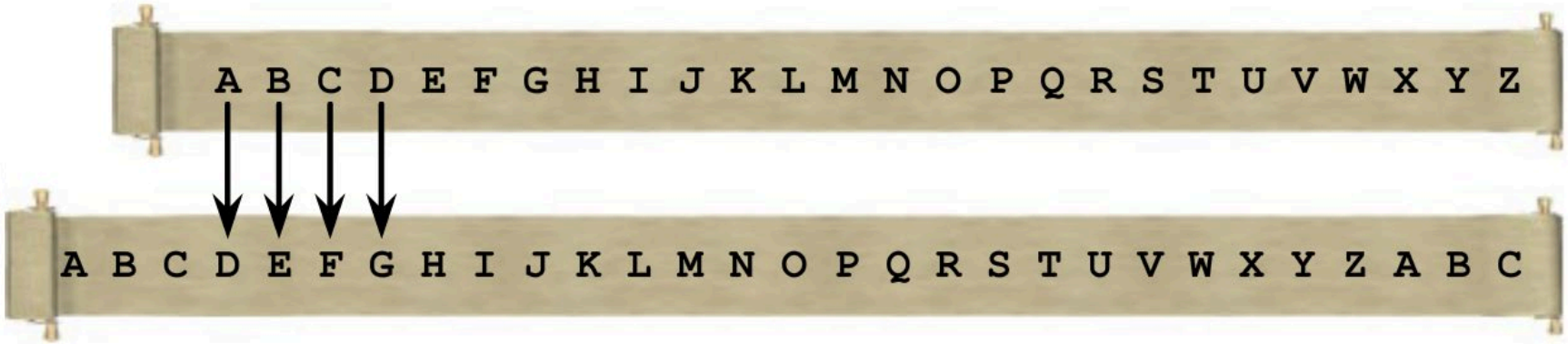
# Scytale

- ~700 BC (f.Kr.)
- Uppfunnet i antikens Grekland
- Meddelandet skrivs på en lång remsa, för att få ut meddelandet måste man snurra remsan



# Caesar-cipher

- ~40 BC
- Bygger på att man flyttar fram bokstäver i alfabetet



# Vigenère

- 1800-talet
- Tabellbaserat med två komponenter:
  - Meddelande
  - Nyckelord

| KEYWORD LETTER | PLAINTEXT LETTER | | | | | | | | | | | | | | | | | | | | | | | | | |
|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|
| | A | B | C | D | E | F | G | H | I | J | K | L | M | N | O | P | Q | R | S | T | U | V | W | X | Y | Z |
| | B | C | D | E | F | G | H | I | J | K | L | M | N | O | P | Q | R | S | T | U | V | W | X | Y | Z | A |
| | C | D | E | F | G | H | I | J | K | L | M | N | O | P | Q | R | S | T | U | V | W | X | Y | Z | A | B |
| | D | E | F | G | H | I | J | K | L | M | N | O | P | Q | R | S | T | U | V | W | X | Y | Z | A | B | C |
| | E | F | G | H | I | J | K | L | M | N | O | P | Q | R | S | T | U | V | W | X | Y | Z | A | B | C | D |
| | F | G | H | I | J | K | L | M | N | O | P | Q | R | S | T | U | V | W | X | Y | Z | A | B | C | D | E |
| | G | H | I | J | K | L | M | N | O | P | Q | R | S | T | U | V | W | X | Y | Z | A | B | C | D | E | F |
| | H | I | J | K | L | M | N | O | P | Q | R | S | T | U | V | W | X | Y | Z | A | B | C | D | E | F | G |
| | I | J | K | L | M | N | O | P | Q | R | S | T | U | V | W | X | Y | Z | A | B | C | D | E | F | G | H |
| | J | K | L | M | N | O | P | Q | R | S | T | U | V | W | X | Y | Z | A | B | C | D | E | F | G | H | I |
| | K | L | M | N | O | P | Q | R | S | T | U | V | W | X | Y | Z | A | B | C | D | E | F | G | H | I | J |
| | L | M | N | O | P | Q | R | S | T | U | V | W | X | Y | Z | A | B | C | D | E | F | G | H | I | J | K |
| | M | N | O | P | Q | R | S | T | U | V | W | X | Y | Z | A | B | C | D | E | F | G | H | I | J | K | L |
| | N | O | P | Q | R | S | T | U | V | W | X | Y | Z | A | B | C | D | E | F | G | H | I | J | K | L | M |
| | O | P | Q | R | S | T | U | V | W | X | Y | Z | A | B | C | D | E | F | G | H | I | J | K | L | M | N |
| | P | Q | R | S | T | U | V | W | X | Y | Z | A | B | C | D | E | F | G | H | I | J | K | L | M | N | O |
| | Q | R | S | T | U | V | W | X | Y | Z | A | B | C | D | E | F | G | H | I | J | K | L | M | N | O | P |
| | R | S | T | U | V | W | X | Y | Z | A | B | C | D | E | F | G | H | I | J | K | L | M | N | O | P | Q |
| | S | T | U | V | W | X | Y | Z | A | B | C | D | E | F | G | H | I | J | K | L | M | N | O | P | Q | R |
| | T | U | V | W | X | Y | Z | A | B | C | D | E | F | G | H | I | J | K | L | M | N | O | P | Q | R | S |
| | U | V | W | X | Y | Z | A | B | C | D | E | F | G | H | I | J | K | L | M | N | O | P | Q | R | S | T |
| | V | W | X | Y | Z | A | B | C | D | E | F | G | H | I | J | K | L | M | N | O | P | Q | R | S | T | U |
| | W | X | Y | Z | A | B | C | D | E | F | G | H | I | J | K | L | M | N | O | P | Q | R | S | T | U | V |
| | X | Y | Z | A | B | C | D | E | F | G | H | I | J | K | L | M | N | O | P | Q | R | S | T | U | V | W |
| | Y | Z | A | B | C | D | E | F | G | H | I | J | K | L | M | N | O | P | Q | R | S | T | U | V | W | X |
| | Z | A | B | C | D | E | F | G | H | I | J | K | L | M | N | O | P | Q | R | S | T | U | V | W | X | Y |

# Enigma

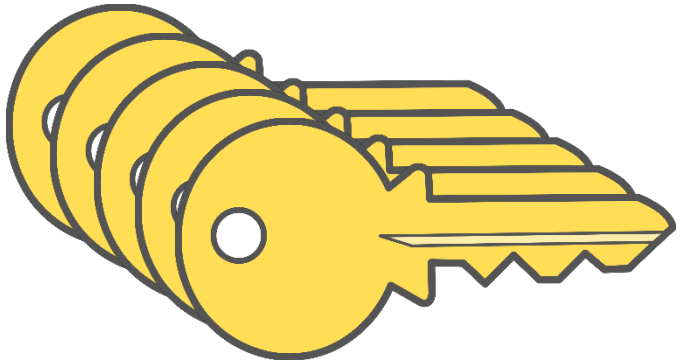
- 1930-talet
- Utvecklat av tyskarna under andra världskriget för att kryptera korta meddelanden
- Filmtips: [The Imitation Game]

# Krypteringstyper

- **Transposition**
  - Byta plats på tecken
  - T.ex. Scytale
- **Substitution**
  - Ersätta tecken
  - T.ex. Caesar-cipher
- **One-time pad**
  - Engångstabeller för kryptering där varje tecken krypteras för sig
  - Inte effektivt då man hela tiden måste generera nya tabeller för nya meddelanden

# Nycklar

- Förr i tiden handlade det om att knäcka hela algoritmen, t.ex. när man knäckte Enigma-maskinen
- Med moderna algoritmer handlar det om att knäcka nycklar
  - Algoritmerna är i de flesta fallen öppna, och ses ofta som oknäckbara



# Nyckelhantering (Key Management)

- Hantering av nycklar är en känslig process, för all säkerhet hänger på att nycklar hålls hemliga
- Det finns vissa nycklar som är svaga och inte bör användas
  - **Exempel:** Ceasar-cipher med nyckel 0 och 26 ger…?
- Aspekter att tänka på:
  - Hur skapar vi nycklar?
  - Hur verifierar vi nycklar?
  - Hur utbyts nycklar över nätet?
  - Hur lagras nycklar?
  - Hur länge ska en nyckel gälla?
  - Hur återkallas en nyckel?

# Nycklar – Längd och antal

- **Nyckellängd (Key length)**
  - Antalet bitar. Ju fler desto säkrare.
- **Nyckelantal (Key space)**
  - Antalet kombinationer som skapas med en viss nyckel-längd

| Length | Key space |
|---|---|
| 2 | 4 |
| 3 | 8 |
| 16 | 65,535 |
| 32 | 4,294,967,296 |
| 40 | 1,099,511,627,776 |
| 56 | 72057594037927936 |
| 64 | 18446744073709551616 |
| 128 | 340282366920938463463374607431768211456 |
| 256 | 115792089237316195423570985008687907853269984665640564039457584007913129639936 |
| 2048 | 32317006071311007300714876688669951960444102669715484032130345427524655138867890893197201411522913463688717960921898019494119559150490921095088152386448283120630877367300996091750197750389652106796057638384067568276792218642619756161838094338476170470581645852036305042887575891541065808607552399123930385521914333389668342420684974786564569494856176035326322058077805659331026192708460314150258592864177116725943603718461857357598351152301645904403697613233287231227125684710820209725157101726931323469678542580656697935045997268352998638215525166389437335543602135433229604645318478604952148193555853611059596230656 |

# Keyspace med olika bitar

- Längre nyckel ger fler kombinationer
  - Svårare att knäcka med **brute force**
- Längre nyckel kräver mer prestanda
- Välj en nyckel som är tillräckligt säker, men som inte påverkar prestanda för mycket

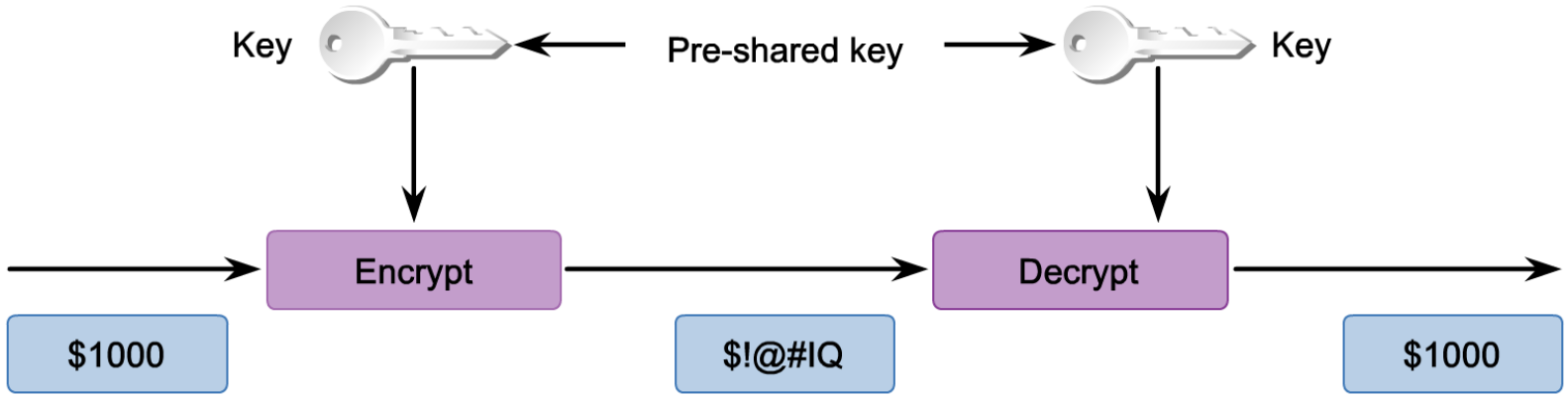
# Krypteringsalgoritmer

# Olika typer av algoritmer

- **Symmetriska algoritmer**
  - Samma nyckel för kryptering och dekryptering
  - Exempel på användningsområde: HTTPS, VPN, SSH, etc.
- **Asymmetriska algoritmer**
  - Olika nycklar för kryptering och dekryptering
  - Exempel på användningsområde: HTTPS, VPN, SSH, etc.

| | Symmetric Key | Asymmetric Key |
|---|---|---|
| **Protection up to 3 years** | 80 | 1248 |
| **Protection up to 10 years** | 96 | 1776 |
| **Protection up to 20 years** | 112 | 2432 |
| **Protection up to 30 years** | 128 | 3248 |
| **Protection against quantum computers** | 256 | 15424 |

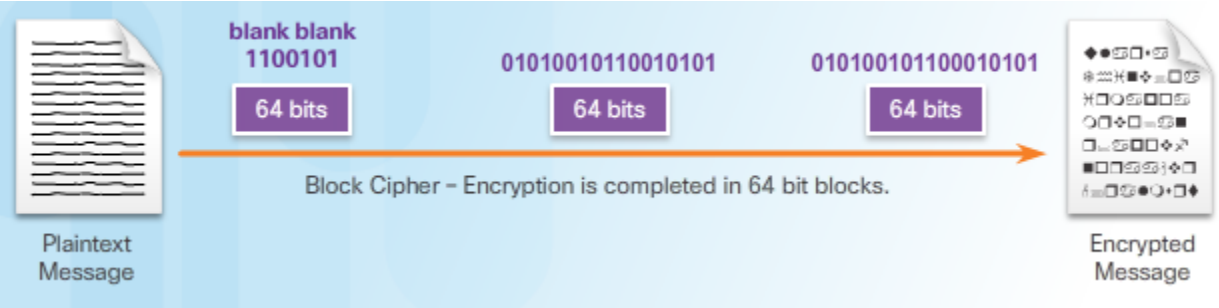
# Symmetrisk kryptering



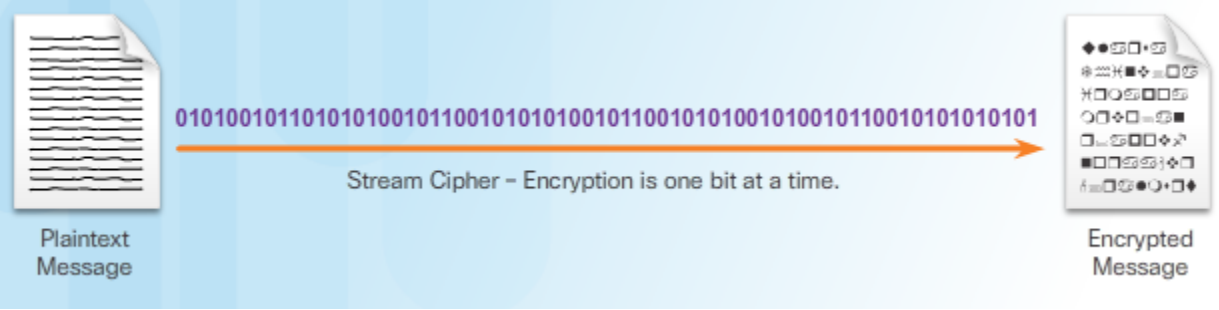

- Använder samma nyckel för att kryptera och dekryptera
  - Kallas ofta **secret key**
- Nycklarna måste finnas på båda enheterna
  - Pre-share (PSK)
  - Key exchange
- Snabbt på grund av enkel matematisk funktion (typ XOR)
- **Exempel:** DES, 3DES, AES, Blowfish

# Block vs. stream

- **Block cipher**
  - Kryptering av ett helt block av bitar i taget, t.ex. vid filkryptering



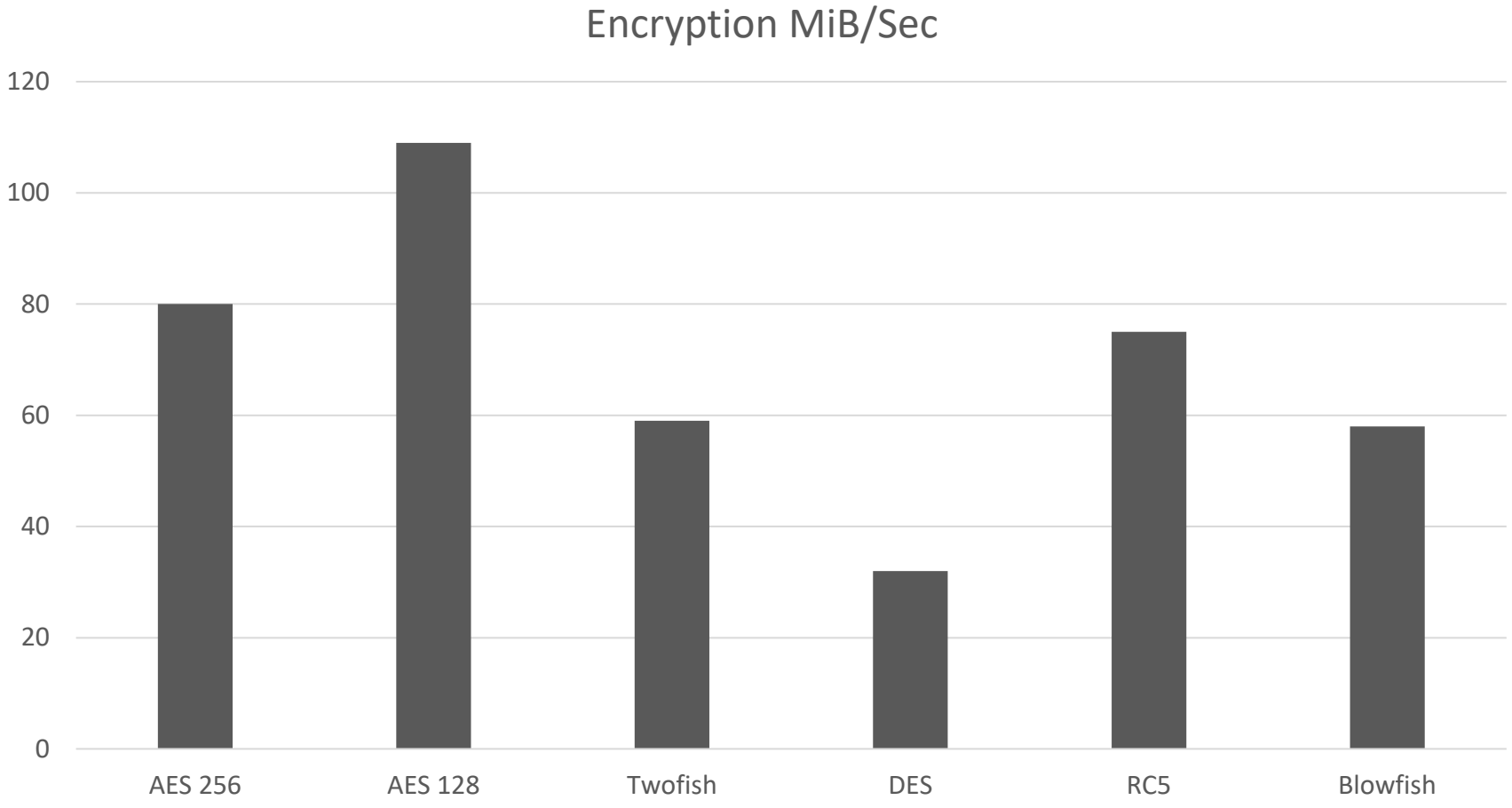

- **Stream cipher**
  - Kryptering av en bit i taget, t.ex. vid kryptering av en ström av data som nätverkskommunikation



# AES

- 1997 gjordes ett initiativ för att ta fram en säker och snabb krypteringsstandard för att ersätta 3DES
- **AES (Advanced Encryption Standard)** fastslogs 2001 av NIST
- 15 olika algoritmer tävlade med varandra och vinnaren var Rijndael-algoritmen (Joan Daemen & Vincent Rijmen)
- Block-baserat, men finns också stream-varianter

# Prestanda symmetriska algoritmer



# Hur utbyter man symmetriska nycklar?

Martin Hellman
Whitfield Diffie

# Hur utbyter man symmetriska nycklar?

- Ofta med hjälp av asymmetriska algoritmer, t.ex. Diffie-Hellman (DH)
- **Diffie-Hellman**
  - Togs fram 1976
  - 512/1024/2048/3072/4096/osv. bitar
  - Väldigt långsam algoritm
  - Används för att ta fram en delad säker nyckel över ett osäkert nätverk

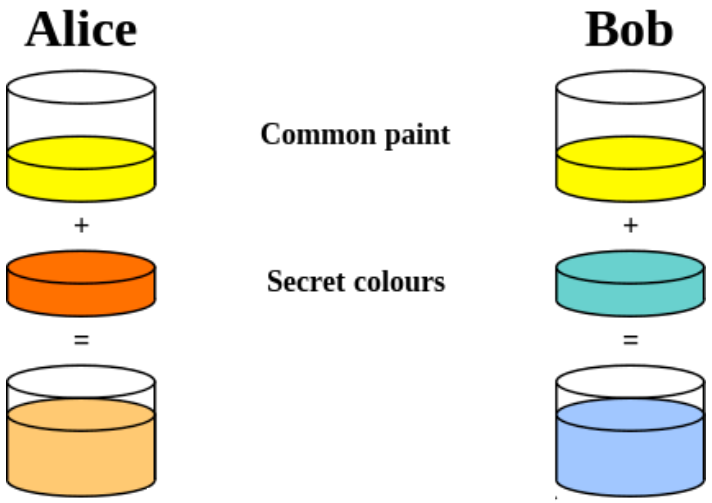
**DH Characteristics**

| | |
|---|---|
| Description | Diffie-Hellman Algorithm |
| Timeline | 1976 |
| Type of Algorithm | Asymmetric |
| Key Size (in bits) | 512, 1024, 2048, 3072, 4096 |
| Speed | Slow |
| Time to Crack (Assuming a computer could try 255 keys per second) | Unknown but considered safe using keys of 2048 or higher |
| Resource Consumption | Medium |

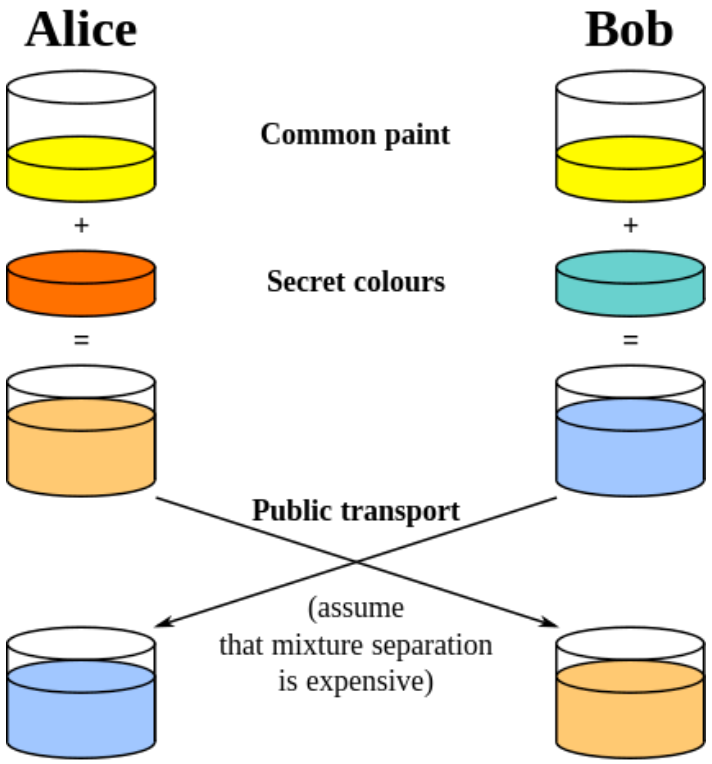
# DH

# DH

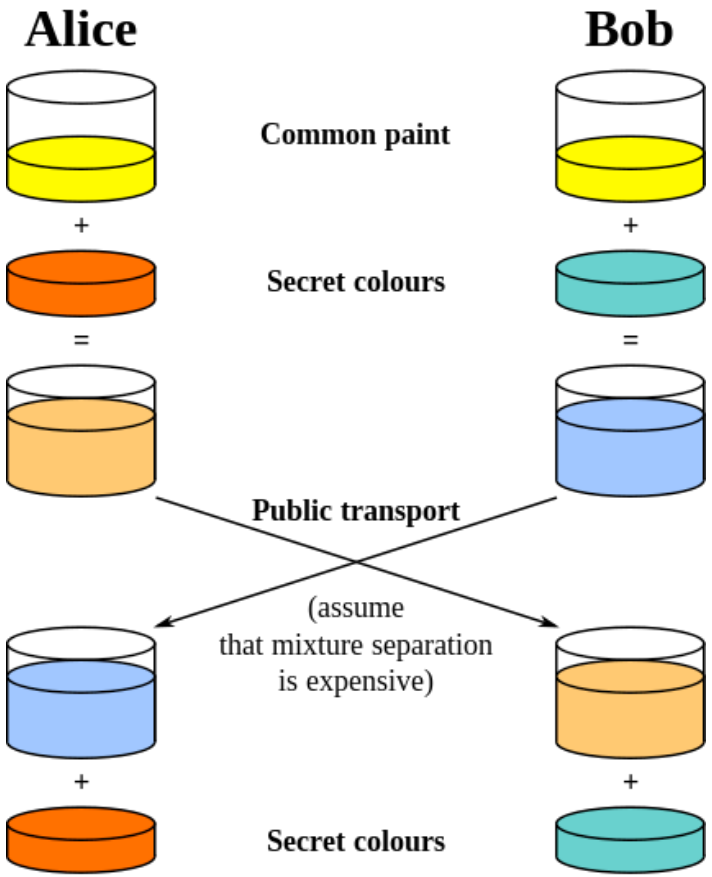
# DH



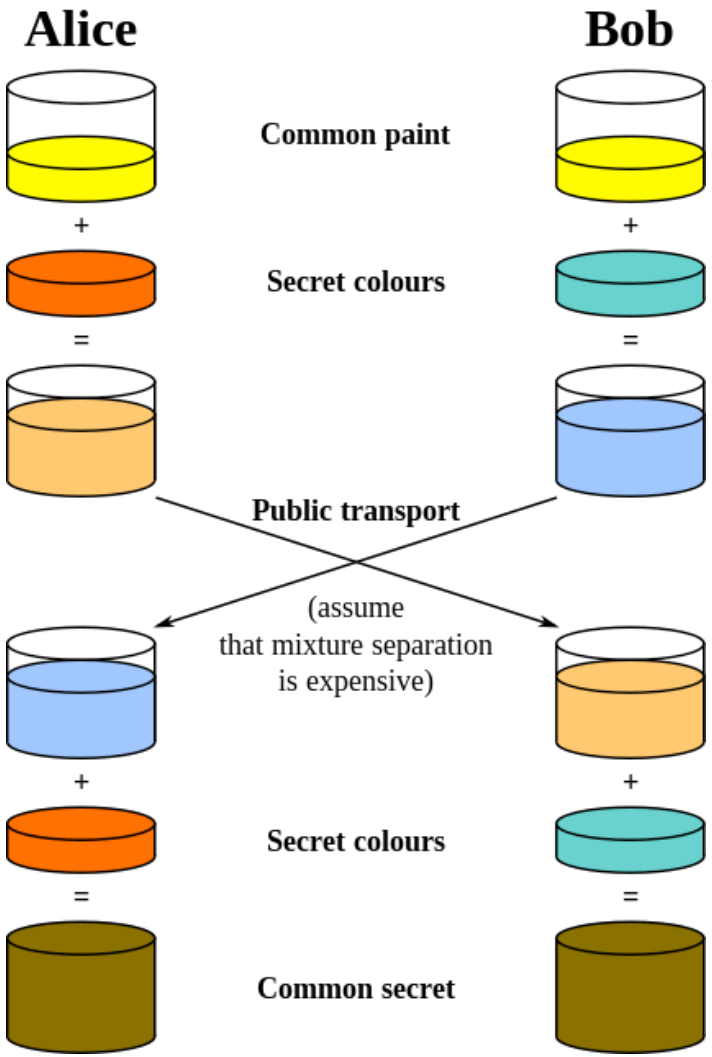
# DH


Alice
Bob
Common paint
+
+
Secret colours
=
=
Public transport
(assume
that mixture separation
is expensive)

# DH

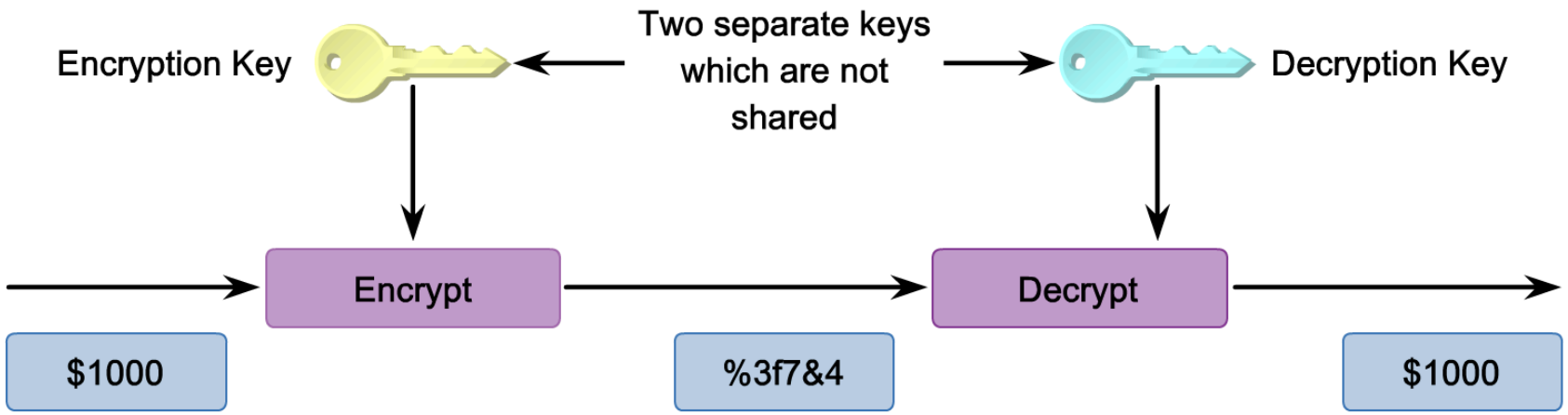

Alice
Bob
Common paint
+
+
Secret colours
=
=
Public transport
(assume
that mixture separation
is expensive)
+
+
Secret colours

# DH


Alice
Bob
Common paint
+
Secret colours
=
Public transport
(assume
that mixture separation
is expensive)
+
Secret colours
=
Common secret

# Asymmetrisk kryptering

- Använder en privat och en publik nyckel
- 1024 – 4096 bitar
- Mycket sämre prestanda än symmetriska algoritmer
- **Exempel:** RSA, Elliptic Curve, (Diffie-Hellman)



# Public key & Private key

- De båda nycklarna använda tillsammans ger:
  - **Konfidentialitet (Confidentiality)** genom att data kan *krypteras med den publika nyckeln och dekrypteras med den privata nyckeln*
  - **Autentisering (Authentication)** genom att det som går att *dekryptera med den publika nyckeln måste vara skickat från rätt avsändare* (som har använt sin privata nyckel)
  - **Dataintegritet (Integrity)** genom att *en meddelandehash kan krypteras med den privata nyckeln*, mottagaren vet då att om det är rätt hash när den är dekrypterad med den publika nyckeln

# Användningsområden

- **Internet Key Exchange (IKE)**
  - Protokoll för att utbyta nycklar i IPsec
- **Secure Socket Layer (SSL) och Transport Layer Security (TLS)**
  - Säker webbkommunikation
- **Pretty Good Privacy (PGP)**
  - Krypterad mailkommunikation
- **Secure Shell (SSH)**
  - Krypterad terminal

# Användningsområden

- SSH
  - Klienten ansluter till servern, servern presenterar sin publika nyckel
  - Via den publika nyckeln förhandlas inställningar och symmetrisk algoritm
  - Klienten genererar en sessionsnyckel
  - Klienten skickar sessionsnyckeln med den publika nyckeln
  - Servern dekrypterar med sin privata nyckel

# Asymmetriska algoritmer

- **Diffie-Hellman (DH)**
  - 512-4096 bitar
  - Används främst för att utbyta symmetriska nycklar
- **Rivest, Shamir and Adleman (RSA)**
  - 512-2048 bitar
  - Används för både för ren kryptering samt signaturer
- **Elliptical Curve (ECC)**
  - Har mindre nycklar med bibehållen säkerhet

# Digitala signaturer

# Digitala signaturer

- Digitala signaturer kan bland annat användas för
  - **Kodsignering** (verifiera att en viss programvara är äkta, ex. Ciscos publika nyckel)
  - **Digitala certifikat** (verifiera identitet hos klient eller organisation, ex. HTTPS)
- Digitala signaturer använder asymmetrisk kryptering för sin funktion
  - En hashsumma kan krypteras med den *privata nyckeln*, mottagaren vet då att om det är en verifierad hashsumma när den är dekrypterad med den *publika nyckeln*
- Digitala signaturer ger:
  - Autentisering (Authentication)
  - Dataintegritet (Integrity)
  - Nonrepudiation

# Algoritmer för digitala signaturer

- **DSA (Digital Signature Algorithm)**
  - Snabbt skapande av signaturer
  - Långsam verifiering av signaturer
- **RSA (Rivest, Shamir, Adelman-Algorithm)**
  - Långsamt skapande av signaturer
  - Snabb verifiering av signaturer
- **ECDSA (Elliptic Curve Digital Signature Algorithm)**
  - Nyare variant av DSA med högre effektivitet

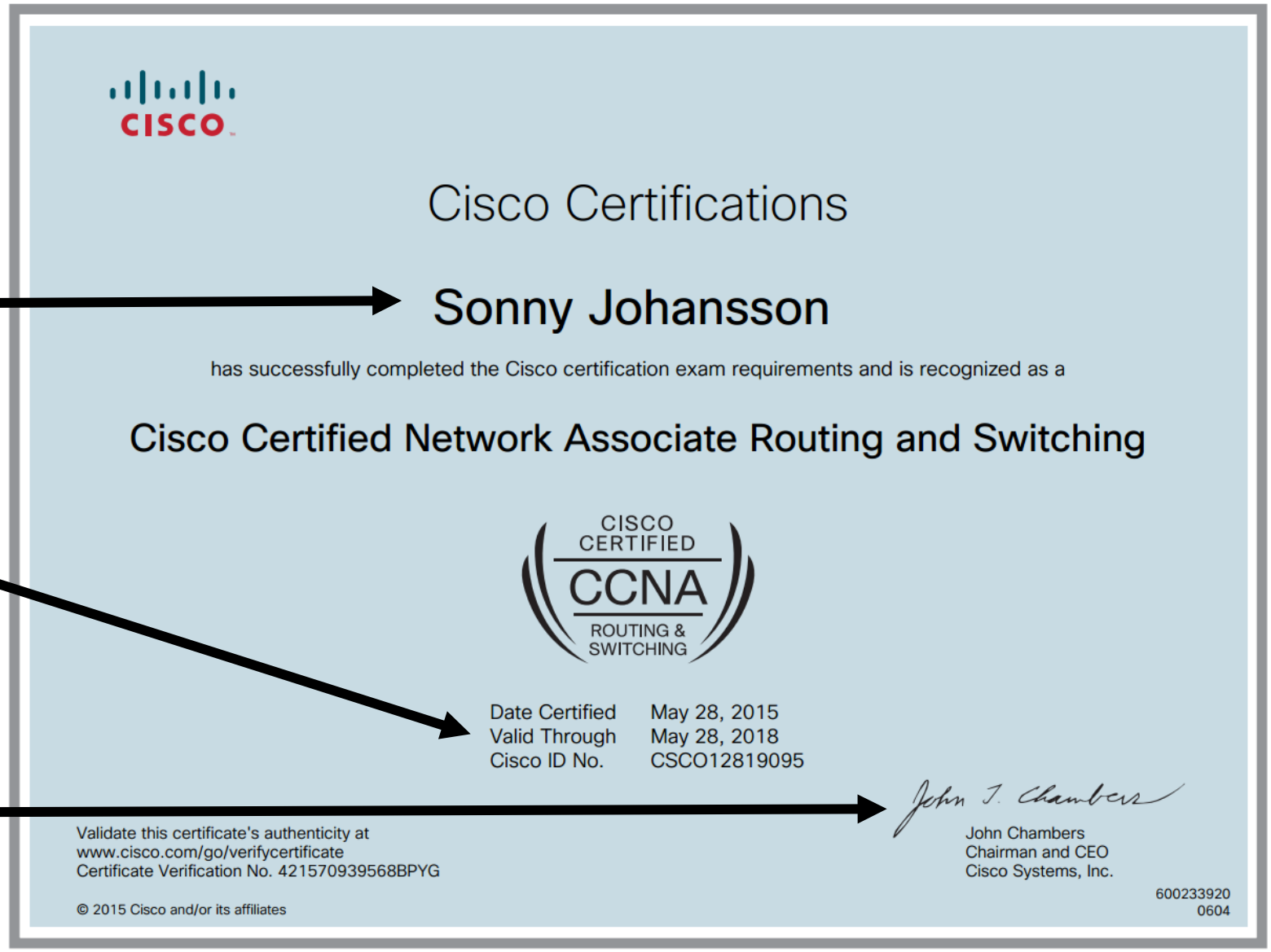
# Digitala certifikat

# Certifikat

**Utfärdat till**

**Giltighetstid**

**Utfärdare och bevis på giltighet**



CISCO

Cisco Certifications

Sonny Johansson

has successfully completed the Cisco certification exam requirements and is recognized as a

Cisco Certified Network Associate Routing and Switching

CISCO CERTIFIED CCNA ROUTING & SWITCHING

| | |
|---|---|
| Date Certified | May 28, 2015 |
| Valid Through | May 28, 2018 |
| Cisco ID No. | CSCO12819095 |

Validate this certificate's authenticity at
www.cisco.com/go/verifycertificate
Certificate Verification No. 421570939568BPYG

John Chambers
Chairman and CEO
Cisco Systems, Inc.

600233920
0604

© 2015 Cisco and/or its affiliates

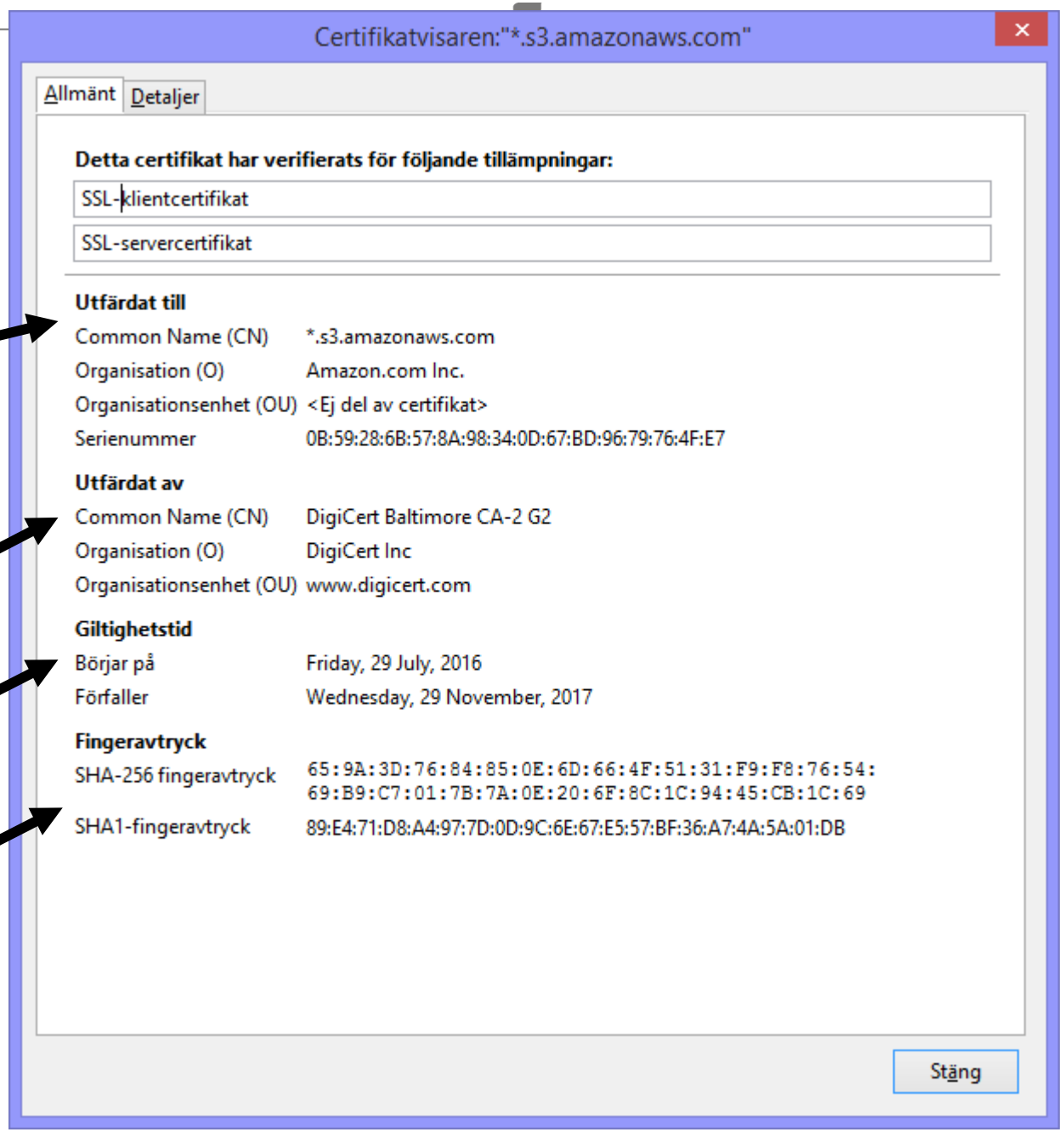
# Digitala certifikat

**Utfärdat till**

**Utfärdare (Certificate Authority)**

**Giltighetstid**

**Bevis på giltighet**



# Digitala certifikat – X.509

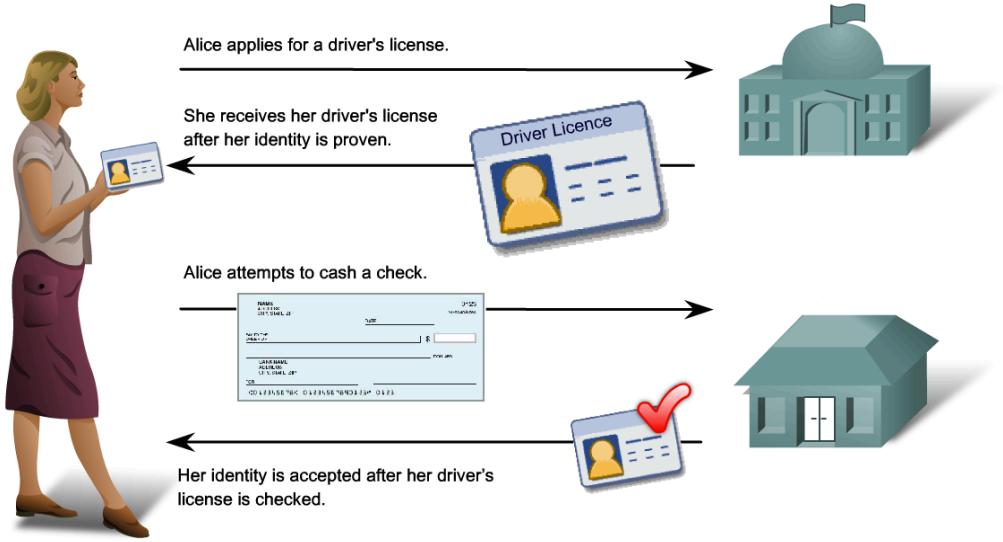
- **X.509** är en ITU-standard som definierar format för certifikat (se föregående slide)
- X.509 kopplar ihop en identitet med en **publik nyckel** via **en digital signatur**
- En identitet kan vara:
  - Ett **hostname**, t.ex. dnlab.se
  - En **organisation**, t.ex. Tekniska högskolan i Jönköping AB
  - En **individ**, t.ex. Viktor Ljunggren

# Digitala certifikat – X.509

- Ett **digitalt certifikat** har två syften:
  - **Fastställa identitet** för ägaren av certifikatet
  - Göra ägarens **publika nyckel tillgänglig**
- För att uppfylla syftena ovan måste vi ha möjlighet att verifiera och tillgängliggöra certifikat via en tredje part, denna infrastruktur kallas **Public-Key Infrastructure (PKI)**
- PKI bygger (ofta) på att det finns en central part, **Certificate Authority (CA),** som båda parter litar på

# CA – exempel

- Ett körkort som utfärdas av Transportstyrelsen, detta körkort kan sedan användas på t.ex. banken för att legitimera sig eftersom banken litar på Transportstyrelsen
- Transportstyrelsen är i detta fallet en **Certificate Authority (CA)**
- **Vilka CAs litar du på?**



# **Demo:** Vilka CAs litar din webbläsare på?

JÖNKÖPING UNIVERSITY

*School of Engineering*